

NEWSLETTER N. 507 of July 26, 2023

Journalism: Stop to invasive photos in homes, even if the person is famous

Work: The Privacy Authority reiterates the no to remote monitoring

Health: The Privacy Authority fines a company for the use of non-anonymized data

Data transfer to the USA: clarifications from the EU Authorities

****Journalism: Stop to invasive photos in homes, even if the person is famous****

Legitimate expectation of privacy. The Authority fines a magazine.

A journalistic outlet must respect the legitimate expectation of privacy enjoyed in one's own home and must always evaluate, on a case-by-case basis, whether the published photos respect the principle of the essentiality of information and are of public interest.

The Personal Data Protection Authority has fined a magazine €40,000 for publishing photographs that captured moments of the private life of a well-known person in their home, in violation of the general principles of processing and the ethical rules governing journalistic activity.

The images depicted the individual, unbeknownst to them, while they were with an acquaintance inside their apartment on the fourth floor of a building. The shots, taken from a car parked on the street, reveal an improper use of "invasive techniques" and, therefore, a collection of personal data, including strictly private data, which violates the principles of fairness and transparency. The fact that the individual is willing to subject themselves to "media scrutiny," as claimed by the publication, cannot legitimize any form of collection and use of data and images concerning them, especially in places like their home where the expectation of privacy is legitimate.

Not only were the images unlawfully obtained, but their subsequent use also violated the rules regarding the processing of personal data. The declared purpose by the owner – to scoop on the romantic relationship between the complainant and the man depicted in the photographs – even if it could be categorized as a type of journalistic information of public interest (at least for a certain audience), cannot justify the infringement of the right to respect for the private life of the individual concerned, even if they are a public figure.

The Authority, in addition to ordering the payment of the fine, has prohibited further dissemination of the photographs, including online and in the historical archive of the publication.

****Work: The Privacy Authority reiterates the no to remote monitoring****

A company fined for violations of privacy regulations and the Workers' Statute.

Compliance with the guarantee procedure provided by the Workers' Statute and the Privacy Code is an essential requirement for the correctness of the processing of personal data of workers in a company.

The reasons presented by a company were not sufficient to avoid a €20,000 fine from the Personal Data Protection Authority for having installed an alarm system whose activation and deactivation relied on the use of fingerprints, a video surveillance system, and an application for the geolocation of certain workers.

The violations emerged from an inspection initiated by the Authority in collaboration with the Special Privacy Protection Unit of the Guardia di Finanza, following a report.

In particular, regarding the video surveillance system, it was found that it not only captured live images but was also capable of picking up sounds and making recordings; the legal representative of the company and their family had access through a smartphone. The application allowed the user to verbally admonish the individuals concerned through the speakers of the system.

The inspection also revealed that the company used an application that, when in use, continuously tracked the employee's location via GPS during their activities, as well as the date and time of the detection, thus constituting unauthorized monitoring of the worker.

The processing of data carried out through the video surveillance system and the localization system was done without the workers having received adequate information and without the guarantee procedures provided by the Workers' Statute being activated (union agreement or, alternatively, authorization from the Labor Inspectorate). Regarding video surveillance, the absence of informational signs on-site was also noted.

In order to further strengthen security measures in the company premises, the Company had also

installed an alarm system whose activation and deactivation relied on

****Processing of Biometric Data (Fingerprints)****

of 21 subjects, including employees.

In this regard, the decision noted that the processing of biometric data, generally prohibited as it falls under the so-called special categories of data (Article 9 GDPR), is only permitted if one of the conditions explicitly provided for in paragraph 2 of Article 9 GDPR is met and, regarding processing carried out within the employment relationship, only when the processing is necessary to fulfill the obligations and exercise the rights of the data controller or the data subject and is provided for by a regulatory provision, circumstances not found in the case at hand.

In addition to the payment of the fine, the Authority has ordered the prohibition of processing the data collected through the video surveillance system and the continuous monitoring of the worker's position.

****Health: The Privacy Authority Sanctions a Company for Use of Non-Anonymized Data****

With Ordinance of December 4, 2023, the Court of Milan suspended, among other things, the executive effectiveness of the provisions of the Authority's Decision No. 226 of June 1, 2023 concerning the publication of the same decision on the Authority's website.

The Privacy Authority imposed a fine of 15,000 euros on a company for unlawfully processing the health data of numerous patients collected from about 7,000 general practitioners (GPs), without adopting suitable anonymization techniques.

The Authority acted following a report from a general practitioner who complained of an alleged violation of privacy regulations by the company, which was engaged in an international project aimed at improving patient care through the collection and analysis of health data.

For this purpose, the GPs participating in the initiative were required to add an additional functionality (so-called add-on) to the management software in use - called "Medico 2000" and provided by a partner IT company - aimed at automatically anonymizing patient data and transmitting it to a database of the same company. In exchange, the doctors received a series of benefits, including financial compensation.

From the investigation by the Authority, it emerged that the functionalities of the so-called add-on, indicated by the company, did not allow for the actual anonymization of the information acquired from the GPs and that therefore the company carried out unlawful processing of pseudonymized personal data in violation of the principles of lawfulness and transparency. The mere replacement of the ID assigned to patients with a cryptographic system or an irreversible hash code - the Authority emphasized - does not constitute, under any circumstances, a suitable measure concerning the requirement for the removal of singularities (single out) necessary to qualify the processing operation as anonymization. This principle was also expressed in the 2014 opinion of the then Article 29 Working Party, according to which "simply relying on the robustness of the cryptographic mechanism as a measure of 'anonymization' of a set of data is misleading, as many other technical and organizational factors affect the overall security of a cryptographic mechanism or hash function."

Among the other violations identified by the Privacy Authority, there is also the incorrect attribution of the role of data controller to the general practitioners, considering that the purposes and means of processing, particularly with regard to the definition of anonymization techniques, were defined by the company.

In the decision, the Authority deemed it necessary to warn all doctors that the use of the add-on of the management software "Medico 2000," as currently configured, constitutes a violation of patient privacy.

****Data Transfer to the USA: Clarifications from EU Authorities****

After the adequacy decision of the European Commission on the "Data Privacy Framework"

The European Data Protection Board (EDPB) has adopted an information note addressed to individuals and organizations transferring data to the United States. The document aims to provide concise and objective guidance on the impact of the recent adequacy decision of the EU Commission regarding the transfer of personal data to the USA, the implications of the Data Privacy Framework (DPF), and the new mechanism for redress concerning national security.

The note clarifies that transfers based on adequacy decisions do not need to be supplemented by additional measures, while transfers to the United States not included in the list provided by the DPF require adequate safeguards, such as standard contractual clauses for data protection or binding corporate rules. In this regard, the EDPB emphasizes that all guarantees implemented by the U.S. government in the context of national security, including the redress mechanism, apply to all data transferred to the United States, regardless of the transfer instrument used.

The information note also specifies that within the context of national security, EU citizens, in order to avail themselves of the new redress mechanism, can file a complaint with their national Authority.

****Data Protection, Regardless of the Tool Used to Transfer Personal Data to the United States.****

With the decision adopted on July 10, 2023, the European Commission has established that the United States provides an adequate level of protection for personal data transferred from the EU to those U.S. organizations included in the list indicated by the Data Privacy Framework, which is managed and published by the U.S. Department of Commerce.

It should be noted that last February, the European Data Protection Board adopted its opinion on the draft adequacy decision of the Commission, with the aim of clarifying the implications for data subjects in the EU and for organizations transferring personal data to the United States.

The first review of the adequacy decision, to verify the full implementation and effectiveness of all elements, is scheduled for next year. Following the first review, and depending on its outcome, the Commission will define the frequency of subsequent reviews, after consulting the EDPB and Member States. The review must, however, be conducted at least every four years.

Read the information note: https://edpb.europa.eu/our-work-tools/our-documents/other/information-not-e-data-transfers-under-gdpr-united-states-after_it

****THE ACTIVITIES OF THE GUARANTOR - FOR THOSE WHO WANT TO KNOW MORE****

The most important interventions and measures recently adopted by the Authority.

****Summer in Privacy - The Guarantor's Tips on Selfies and Photos, Protection of Smartphones and Tablets, Online Shopping, Use of Apps, Chats, and Social Networks While on Vacation (and Beyond) - July 20, 2023****

****NEWSLETTER of the Guarantor for the Protection of Personal Data**** (Registered at the Court of Rome No. 654 of November 28, 2002).

Responsible Director: Baldo Meo.

Direction and Editorial Office: Guarantor for the Protection of Personal Data, Piazza Venezia, No. 11 - 00187 Rome.

Tel: 06.69677.2751 - Fax: 06.69677.3785

The newsletter is available on the website www.gpdp.it